

PRD — VaultKit: Static Personal Credential & Info Manager

Versi: 1.0
Tanggal: 14 Mei 2026
Status: Draft
Platform: GitHub Pages (static site, zero backend)

1. Ringkasan Produk

VaultKit adalah aplikasi web statis yang di-host di GitHub Pages, berfungsi sebagai **personal vault** untuk menyimpan credential, nomor-nomor penting, dan informasi sensitif secara aman — sepenuhnya di sisi klien (browser), tanpa server, tanpa database, tanpa transmisi data ke mana pun.

Semua data terenkripsi di browser pengguna sendiri menggunakan **AES-256-GCM** dengan kunci yang diturunkan dari master password melalui **PBKDF2**. Data hanya tersimpan di `localStorage` milik pengguna dan dapat diekspor sebagai file `.vaultkit` terenkripsi sebagai backup.

2. Masalah yang Diselesaikan

Masalah	Kondisi Saat Ini
Credential berserakan di banyak tempat	Catatan fisik, sticky note, file teks biasa
Credential hilang saat ganti device	Tidak ada mekanisme sync/backup
Password manager berbayar / perlu akun	Bergantung pada layanan pihak ketiga
Nomor penting sulit dicari cepat	Tersebar di berbagai grup WA, foto, email

3. Target Pengguna

Primary: Developer & tech-savvy individual yang mengelola banyak akun layanan (hosting, cloud, database, API, domain, PLN, dll).

Secondary: Profesional umum yang butuh tempat menyimpan informasi penting (nomor KTP, BPJS, SIM, langganan, PIN).

4. Prinsip Desain

1. **Zero Knowledge** — Tidak ada data yang meninggalkan browser pengguna.
 2. **Offline First** — Berfungsi penuh tanpa koneksi internet setelah load pertama.
 3. **Single File Portable** — Seluruh app bisa berjalan dari 1 file HTML jika diperlukan.
 4. **Encrypt Everything** — Tidak ada plaintext credential yang tersimpan, bahkan di `localStorage`.
 5. **No Account Required** — Master password adalah satu-satunya kunci.
-

5. Fitur Utama

5.1 Autentikasi & Keamanan Vault

Master Password Setup (pertama kali)

- Pengguna membuat master password (minimal 12 karakter)
- Password di-hash dengan `PBKDF2-SHA256` (100.000 iterasi, salt acak 16 bytes)
- Hash disimpan di `localStorage` untuk verifikasi login
- Kunci enkripsi AES-256 diturunkan dari password + salt (terpisah dari hash verifikasi)

Login ke Vault

- Input master password → derivasi kunci → dekripsi data di memori
- Auto-lock setelah idle 15 menit (configurable)
- Tidak ada "Lupa Password" — ini by design (zero knowledge)
- Opsional: PIN 6 digit sebagai shortcut (unlock sementara, bukan pengganti master password)

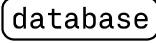
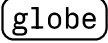
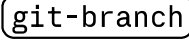
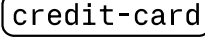
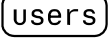
Session Management

- Data dekripsi hanya ada di JavaScript runtime (RAM), tidak di-persist dalam kondisi dekripsi
 - Saat tab ditutup / auto-lock: kunci enkripsi di-clear dari memori
 - Tidak menggunakan `sessionStorage` (bisa di-inspect)
-

5.2 Credential Manager

Menyimpan credential untuk berbagai kategori layanan:

Kategori Bawaan:

Kategori	Ikon	Contoh Field
Google / Email		Email, Password, Recovery Phone, 2FA Backup Codes
Hosting		Provider, URL, Username, Password, SSH Key (hint)
Database		Host, Port, DB Name, Username, Password
Domain & DNS		Registrar, Username, Password, Domain List
API & Token		Service Name, API Key, Secret, Scope, Expire Date
VPS / Cloud		Provider, IP, Root Password, SSH Key Note
Git & DevOps		Platform, Username, PAT Token, Org
Kuangan		Bank, No Rekening, Username m-Banking, PIN hint
Social Media		Platform, Username, Password, Email terdaftar
Langganan		Layanan, Email, Password, Tanggal Renewal
Custom		Field bebas (key-value pairs)

Fitur per Credential:

- Quick copy (klik icon → copy ke clipboard, auto-clear setelah 30 detik)
- Reveal/hide field sensitif (password, token)
- Tag & search
- Tanggal dibuat & terakhir diubah
- Notes (catatan bebas, terenkripsi)
- Password strength indicator
- Deteksi duplikasi email/username

5.3 Info Penting (Personal Records)

Menyimpan nomor-nomor dan informasi statis yang sering dibutuhkan:

Kategori Bawaan:

Kategori	Contoh Field
Identitas	NIK (KTP), Nomor KK, NPWP, Passport, SIM
BPJS & Kesehatan	No. BPJS Kesehatan, No. BPJS Ketenagakerjaan
Kendaraan	No. Polisi, No. Rangka, No. Mesin, Tanggal STNK
Utilitas	No. Pelanggan PLN, ID Pelanggan PDAM, No. Meter
Komunikasi	No. HP (semua SIM), Provider, Masa Aktif
Properti	No. Sertifikat, IMB, PBB SPPT
Kode Penting	PIN ATM (hint), Kode Brankas, dll
Custom Record	Field bebas

5.4 Tools Tambahan (Sidebar)

Alat-alat kecil yang berguna, tidak butuh login vault:

Tool	Fungsi
Password Generator	Buat password kuat dengan konfigurasi
UUID Generator	Generate UUID v4
Base64 Encode/Decode	Encode/decode string
JWT Decoder	Decode payload JWT tanpa verifikasi
Hash Generator	MD5, SHA-1, SHA-256, SHA-512 dari string
TOTP Generator	2FA code dari secret key (untuk backup OTP)
IP & Network Info	Cek IP publik, info browser
Epoch Converter	Unix timestamp ↔ Human readable
Diff Checker	Bandungkan dua teks
URL Encoder/Decoder	Encode/decode URL
JSON Formatter	Pretty print & validate JSON
Regex Tester	Test regex pattern

5.5 Backup & Import/Export

Export:

- Export semua data sebagai file `.vaultkit` (JSON terenkripsi dengan AES-256-GCM)
- Export hanya kategori tertentu
- QR Code export untuk data tunggal (field individual)

Import:

- Import dari file `.vaultkit`
- Import dari CSV (untuk migrasi dari spreadsheet)
- Import dari format Bitwarden JSON (compatibility layer)

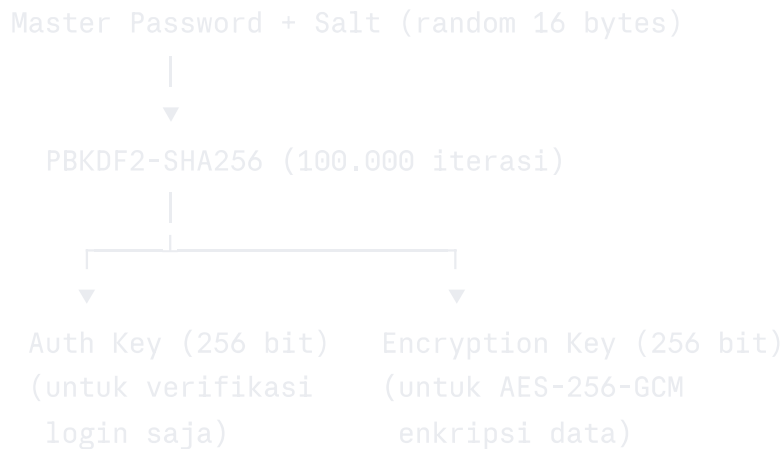
Sync (optional / future):

- Sync manual via file (simpan ke Google Drive / Dropbox secara manual)

- Tidak ada auto-sync ke server manapun
-

6. Arsitektur Keamanan

6.1 Key Derivation



Auth Key dan Encryption Key diturunkan dari salt yang berbeda sehingga:

- Verifikasi login tidak mengekspos kunci enkripsi
- Kunci enkripsi tidak bisa di-reverse dari hash verifikasi

6.2 Enkripsi Data



- Setiap operasi write menggunakan IV baru (tidak pernah reuse)
- Auth tag GCM memastikan integritas data (tidak bisa dimodifikasi tanpa deteksi)
- IV disimpan bersama ciphertext (tidak rahasia, tapi unik per operasi)

6.3 Struktur localStorage

```
localStorage:
├─ vaultkit_meta      → { version, created_at, hint (optional) }
├─ vaultkit_auth      → { salt_auth, pbkdf2_hash, iterations }
├─ vaultkit_salt_enc  → Salt untuk derivasi Encryption Key
├─ vaultkit_data      → { iv, ciphertext, auth_tag } (AES-256-GCM)
```

Tidak ada plaintext credential yang tersimpan di localStorage.

6.4 Memory Safety

- Setelah dekripsi, data ada di JavaScript object di memori
- Auto-lock via `setTimeout` + `document.addEventListener('visibilitychange')`
- Saat lock: kunci di-overwrite dengan zero bytes sebelum di-null (best effort di JS)
- Tidak menggunakan Web Workers untuk operasi kriptografi (menghindari complexity, semua di main thread dengan Web Crypto API)

6.5 Content Security Policy

```
Content-Security-Policy:
  default-src 'self';
  script-src 'self' 'unsafe-inline';
  style-src 'self' 'unsafe-inline';
  connect-src 'none';
  img-src 'self' data:;
  object-src 'none';
  base-uri 'self';
```

`connect-src 'none'` memastikan tidak ada request jaringan dari JavaScript.

7. Tech Stack

Layer	Pilihan	Alasan
Hosting	GitHub Pages	Free, HTTPS otomatis, CDN global
Build	Vanilla HTML/CSS/JS atau Vite	Tidak butuh server build yang kompleks
CSS Framework	PicoCSS	Minimal, semantic, cocok untuk tools UI

Layer	Pilihan	Alasan
Interactivity	HTMX + Alpine.js	Ringan, no-build-step
Kriptografi	Web Crypto API (native browser)	Built-in, tidak butuh library eksternal
Icons	Tabler Icons (SVG sprite)	MIT license, lightweight
Storage	localStorage + File API	Sepenuhnya offline-capable

Catatan: Karena ini static site di GitHub Pages, **tidak ada Django**. Django hanya relevan jika kelak dibutuhkan backend (sync server, sharing). Untuk fase ini: pure frontend.

8. Struktur File Proyek

```
vaultkit/
├─ index.html           # Entry point, setup / login screen
├─ app.html             # Main app (setelah login)
├─ assets/
│  ├─ css/
│  │   ├─ pico.min.css
│  │   └─ app.css
│  └─ js/
│     ├─ crypto.js      # Key derivation, AES-GCM encrypt/decrypt
│     ├─ vault.js       # Vault CRUD operations
│     ├─ ui.js          # DOM rendering, event handlers
│     └─ tools/         # Satu file per tool
│        ├─ password-gen.js
│        ├─ totp.js
│        ├─ jwt-decoder.js
│        └─ ...
│     └─ alpine.min.js
├─ icons/
│  └─ tabler-sprite.svg
├─ tools/               # Standalone tool pages (no vault required)
│  ├─ index.html        # Tools hub
│  ├─ password-gen.html
│  ├─ uuid.html
│  └─ ...
├─ _config.yml          # GitHub Pages config
└─ README.md
```


9. User Flow

First Time Setup

1. Buka vaultkit.github.io
 2. Klik "Create New Vault"
 3. Input Master Password (+ konfirmasi)
 4. Opsional: Set password hint (plain text, bukan password itu sendiri)
 5. Vault kosong terbuka → siap diisi

Login Harian

1. Buka app
 2. Input master password
 3. PBKDF2 derivasi kunci → coba dekripsi data
 4. Jika berhasil: vault terbuka
 5. Jika gagal: "Password salah" (delay 2 detik untuk anti-brute-force)

Tambah Credential

1. Klik "+ Add" di kategori yang relevan
 2. Isi form (template sesuai kategori)
 3. Klik Save → data terenkripsi & disimpan ke localStorage
 4. Konfirmasi: "Saved" toast notification

Export Backup

1. Settings → Export Vault
 2. Pilih: Export All / Export Category
 3. Klik Export → download file .vaultkit
 4. File berisi JSON terenkripsi (tidak terbaca tanpa master password)

10. Non-Functional Requirements

Aspek	Target
Load time	< 1 detik (semua aset < 200KB total)

Aspek	Target
Offline support	100% setelah load pertama (Service Worker)
Responsif	Mobile-first, layar 320px s/d 2560px
Aksesibilitas	WCAG 2.1 AA (keyboard navigable, screen reader friendly)
Browser support	Chrome 90+, Firefox 88+, Safari 14+, Edge 90+
Kapasitas data	~5MB localStorage (cukup untuk ribuan entries)

11. Batasan & Risiko

Batasan	Dampak	Mitigasi
Data hanya di 1 browser/device	Data hilang jika clear browser data	Wajibkan export backup berkala, tampilkan reminder
Tidak ada "Forgot Password"	Jika lupa master password, data tidak bisa direcovery	Password hint, anjurkan simpan master password di tempat aman
localStorage bisa di-clear oleh user	Kehilangan data	Export backup, edukasi pengguna
GitHub Pages tidak bisa menerima POST	Tidak bisa ada server-side apapun	Ini memang by design — zero backend
JavaScript bisa diinject di ekstensi browser	Ekstensi jahat bisa baca memori	Anjurkan hanya buka di browser bersih tanpa ekstensi

12. Roadmap

v1.0 — MVP

- ☐ Master password setup & login
- ☐ AES-256-GCM enkripsi/dekripsi
- ☐ CRUD credential (Google, Hosting, DB, API, Custom)
- ☐ CRUD personal records (KTP, PLN, BPJS, dll)
- ☐ Quick copy dengan auto-clear clipboard

- ☐ Search & filter
- ☐ Export/Import .vaultkit
- ☐ Password Generator tool
- ☐ Auto-lock

v1.1 — Polish

- ☐ TOTP/2FA code generator
- ☐ JWT Decoder
- ☐ UUID Generator
- ☐ Import dari Bitwarden JSON
- ☐ Password strength checker
- ☐ Deteksi credential kadaluarsa (domain, SSL, langganan)

v1.2 — Power Features

- ☐ PIN shortcut (biometric via WebAuthn jika tersedia)
- ☐ Multiple vault (pisahkan personal vs work)
- ☐ Diff Checker, JSON Formatter, Hash Generator
- ☐ QR code export per field
- ☐ Service Worker untuk offline penuh

v2.0 — Optional Sync (Masa Depan)

- ☐ Sync via file ke Google Drive API (manual trigger)
 - ☐ Shared vault (hanya baca) via encrypted link
-

13. Keputusan Desain yang Perlu Didiskusikan

- PBKDF2 vs Argon2:** Argon2 lebih kuat tapi belum native di Web Crypto API, butuh WASM polyfill. Rekomendasi: mulai dengan PBKDF2 (100k iterasi), upgrade ke Argon2 di v1.1.
- localStorage vs IndexedDB:** localStorage lebih simpel tapi kapasitas ~5MB. IndexedDB bisa menampung lebih banyak tapi API lebih kompleks. Rekomendasi: localStorage untuk v1.0, IndexedDB sebagai fallback jika kapasitas melebihi 4MB.
- PIN Shortcut:** PIN yang disimpan perlu bisa mendekripsi vault, artinya Encryption Key perlu di-wrap dengan PIN key dan disimpan. Ini menambah attack surface. Rekomendasi: implementasikan di v1.1 saja setelah arsitektur kunci lebih solid.
- GitHub Pages URL:** Bisa pakai `username.github.io/vaultkit` atau custom domain. Custom domain (misal `vaultkit.tools`) lebih professional dan memudahkan bookmark.